

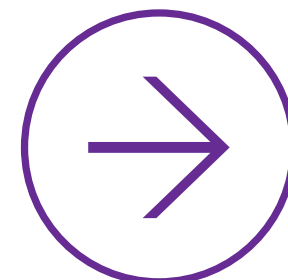


Application & Security

Recipe for a happy marriage...



Your first call when it comes to IT Security!



Agenda

Agenda

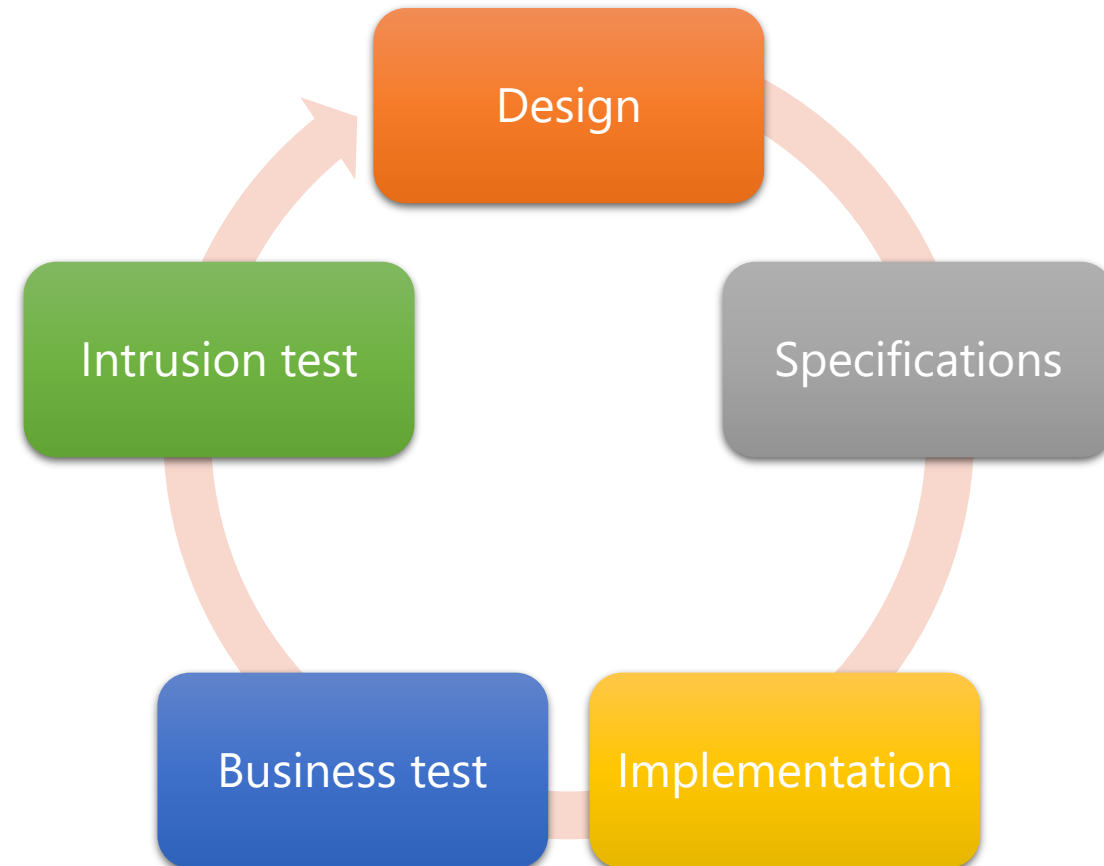
- Common position of the Application Security in the SDLC
- Benefits to integrate AppSec earlier in the project
- Which kind of validations can be integrated?
- What is the impact on the project cost?
- Benefits of the "Security As A Service" approach
- Example: Security checks in a Continuous Integration Platform
- Our Software Factory for our own products



Application & Security

Common position of the Application Security in the SDLC

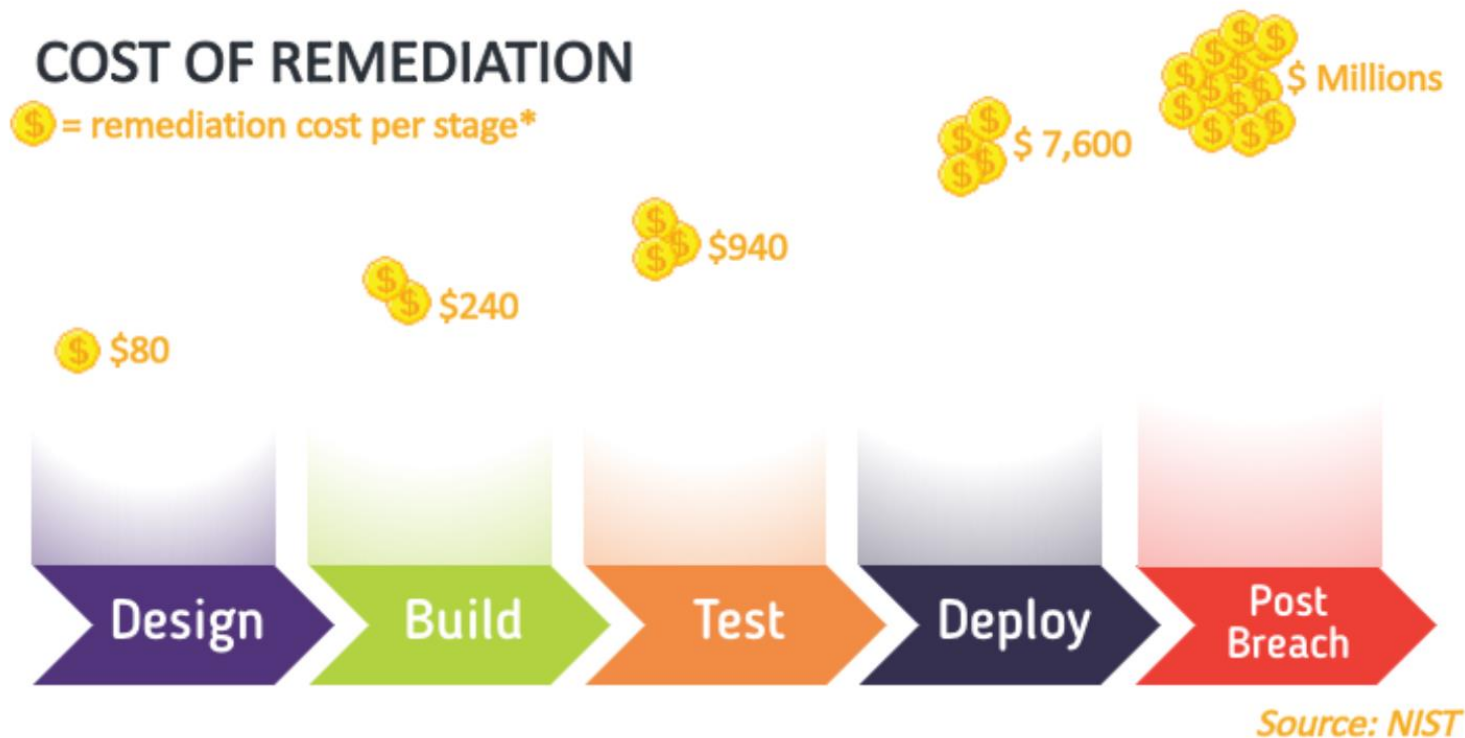
- Application Security is often limited:
 - To validation before the production deployment of the application;
 - To an intrusion test for which security consultants do not have time to acquire business knowledge;
 - To perform an intrusion test in a timeframe that does not allow security consultants to deeply inspect the target to evaluate:
 - Average assessment time is a single week;
 - Remember the last application for which you have asked for a intrusion test:
 - How many business features?
 - How many user interfaces?
 - How many authorization roles?



Application & Security

Benefits to integrate AppSec earlier in the project

- A security vulnerability is a bug so, the later it is discovered, the more it costs to fix...



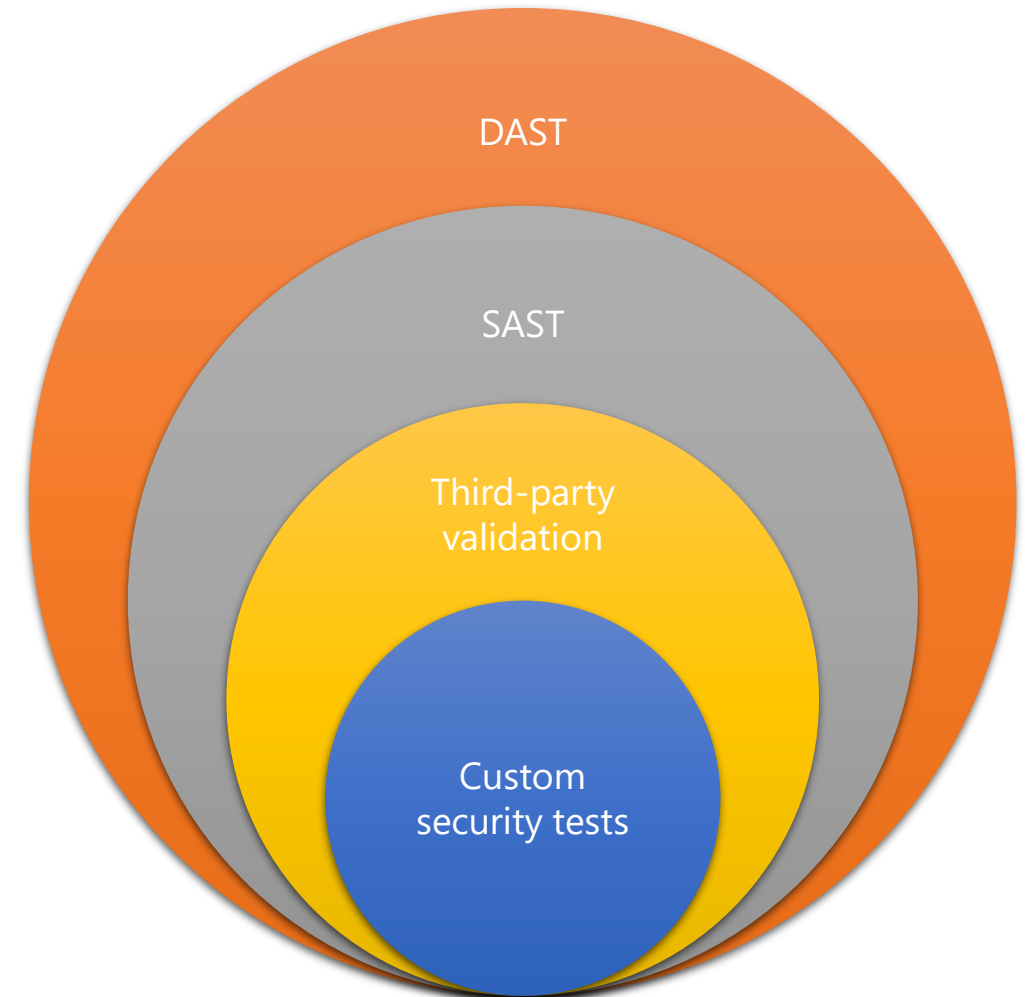
→ Include AppSec in the project life will enable you to:

- ☑ Define abuse cases (technical + business) for each business feature and associate countermeasures;
- ☑ Clearly define the expected security level of the application;
- ☑ Define test cases to keep the same security level when the application will become in maintenance cycle;
- ☑ Ensure the security posture of the application when the implementation is outsourced;
- ☑ Challenge the provider about the security posture when a application is acquired;
- ☑ Find malicious or rogue code;
- ☑ Avoid extra cost billed by the application provider when security issues are found during an assessment.

Application & Security

Which kind of validations can be integrated?

- The following validations can be integrated in a Software Development Life Cycle:
 - **Dynamic Application Security Testing:** Can be **manual and/or automated**. The goal is to analyze the application code at runtime to find issues.
 - **Static Application Security Testing:** Can be **manual and/or automated**. The goal is to review the application code (sometime binaries) in order to find issues.
 - **Third-party validation:** The goal is to ensure that the libraries used by the application do not contain security issues (Common Vulnerabilities and Exposures - CVE).
 - **Custom security tests:** The goal is to define Unit or Integration oriented security tests that will validate specific security points like for example authorization matrix, specific business abuse cases, Web Application Firewall rules...
- *Automated SAST/DAST will not find the same issues than a manual SAST/DAST because a tool cannot fully understand your business and the related abuse cases so, they complement one another!*



Application & Security

What is the impact on the project cost?

- Security implementation is not free, there are cascading costs due to additional tasks:
 - **Business analysts:**
 - For every business feature definition, associated abuse cases must be defined so, they must be assisted by the security department or consultant in order to think like "Hackers".
 - **Architects:**
 - They must identify and design countermeasures for each abuse case.
 - **Developers:**
 - They must identify how to integrate the countermeasures and implement them.
 - **Security department:**
 - They must choose and buy adequate SAST / DAST tools that cover every technology used by the company.
 - They must integrate these tools into the SDLC used by the company.
 - They must support development teams for integration and usage of these tools.
 - They must perform manual SAST / DAST audit on company projects.
- **And hidden costs...**
 - Tools generate reports that must be analyzed by people with AppSec background in order to:
 - Identify False-Positive and False-Negative issues.
 - Tune the tools according to application context and identified abuse cases.



Application & Security

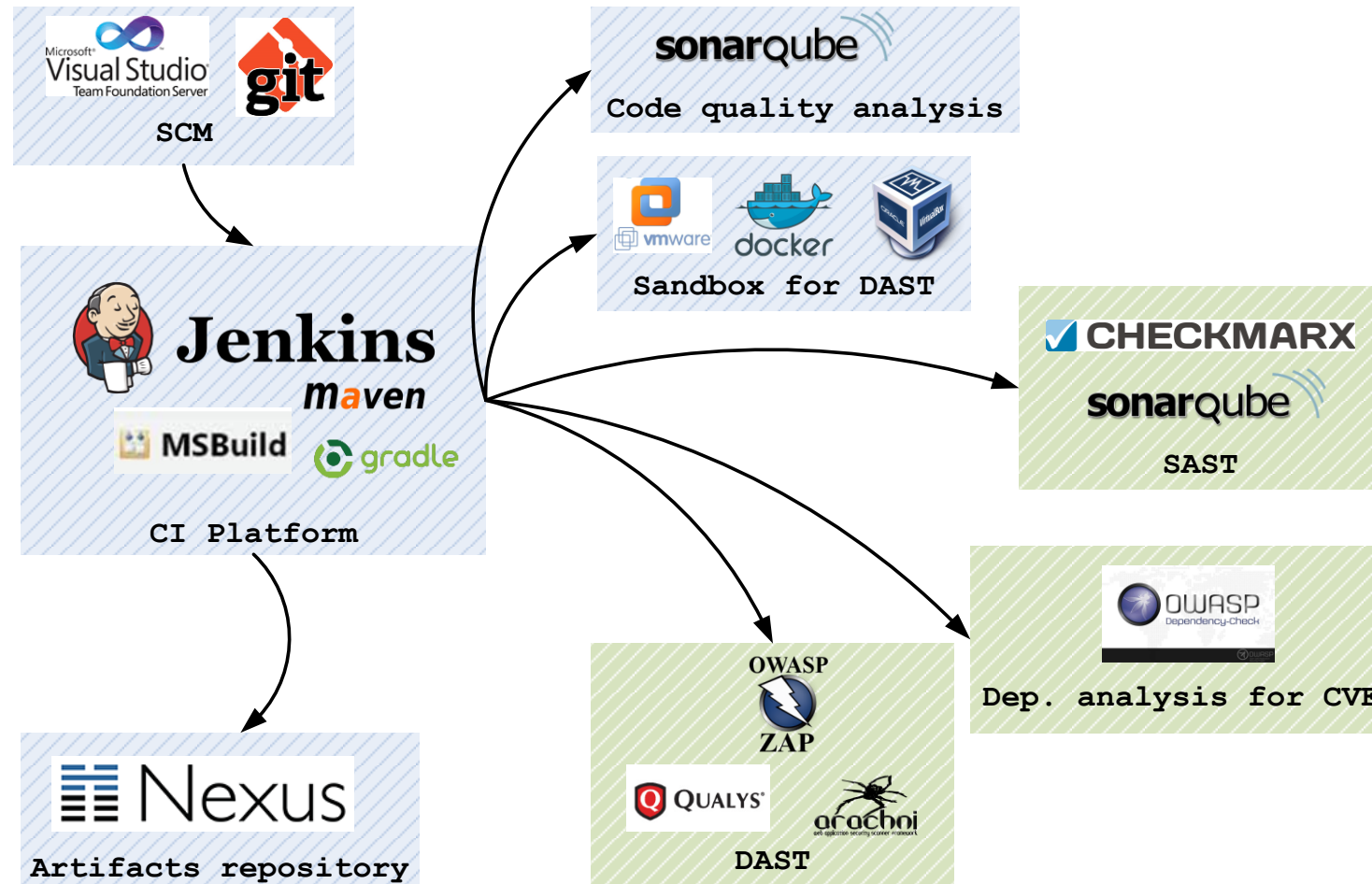
Benefits of the "Security As A Service" approach

- Security tasks can be delegated to an AppSec partner using the following approach:
 - The AppSec partner will help business analysts to define abuse cases thanks to the "Hackers" mindset of the security partner.
 - SAST / DAST manual tasks (pentests & code reviews) and custom security tests definition can be delegated with a close integration in the company SDLC:
 - AppSec partner's consultants have fixed days in each SDLC phase of a project allowing a scheduling in term of planning and budget.
 - SAST / DAST / Third-party validation automated tasks can be delegated in order to let an AppSec partner:
 - Analyze the application with a tool provided by the Security partner in the Cloud.
 - Analyze the report.
 - Provide a consolidated view to architects and developers with only real issues and associated countermeasures.
- *AppSec partner will create the bridge in term of security between the business and the development teams...*



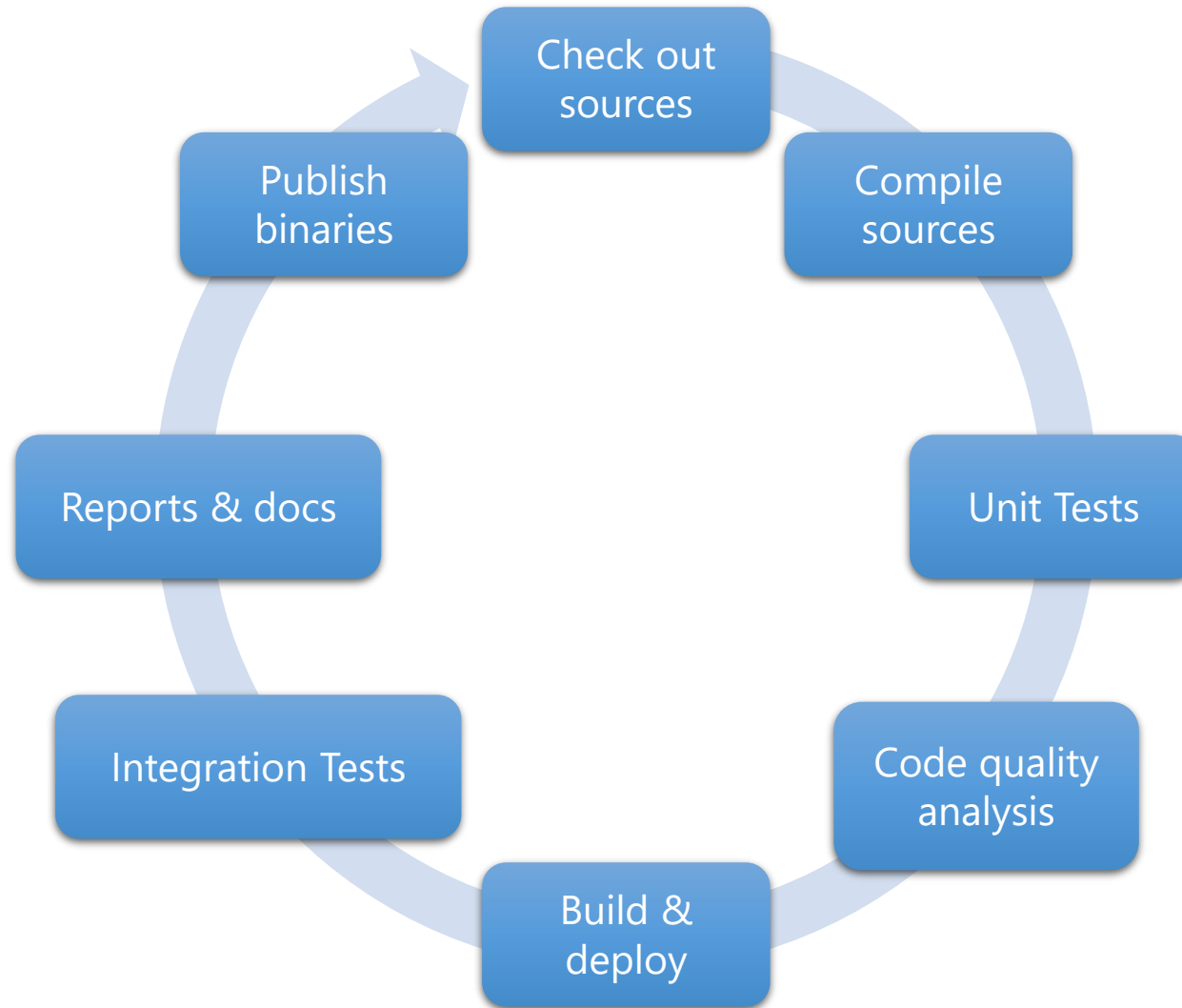
Application & Security

Example: Security checks in a Continuous Integration Platform



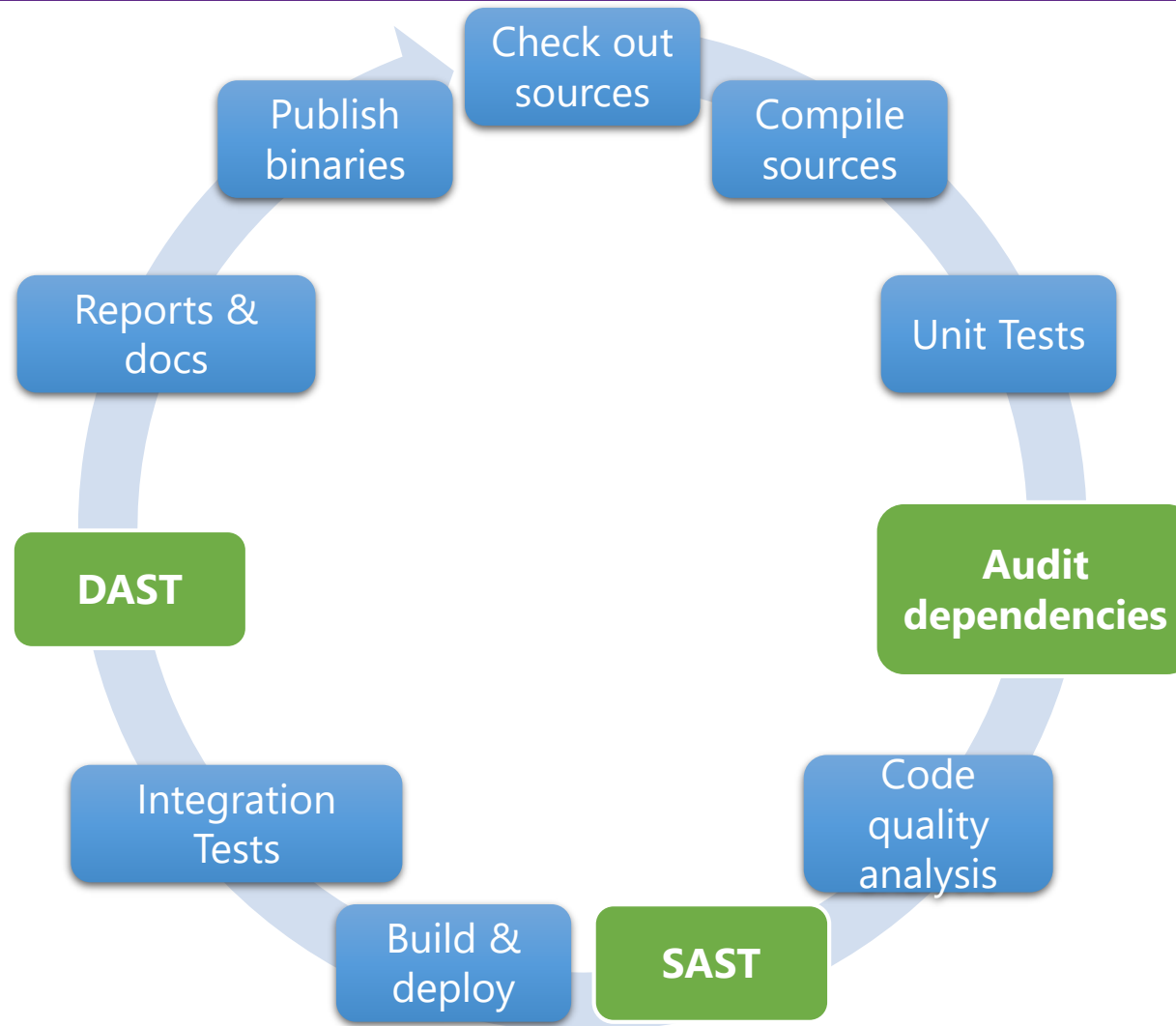
Application & Security

Example: Typical Continuous Integration Platform



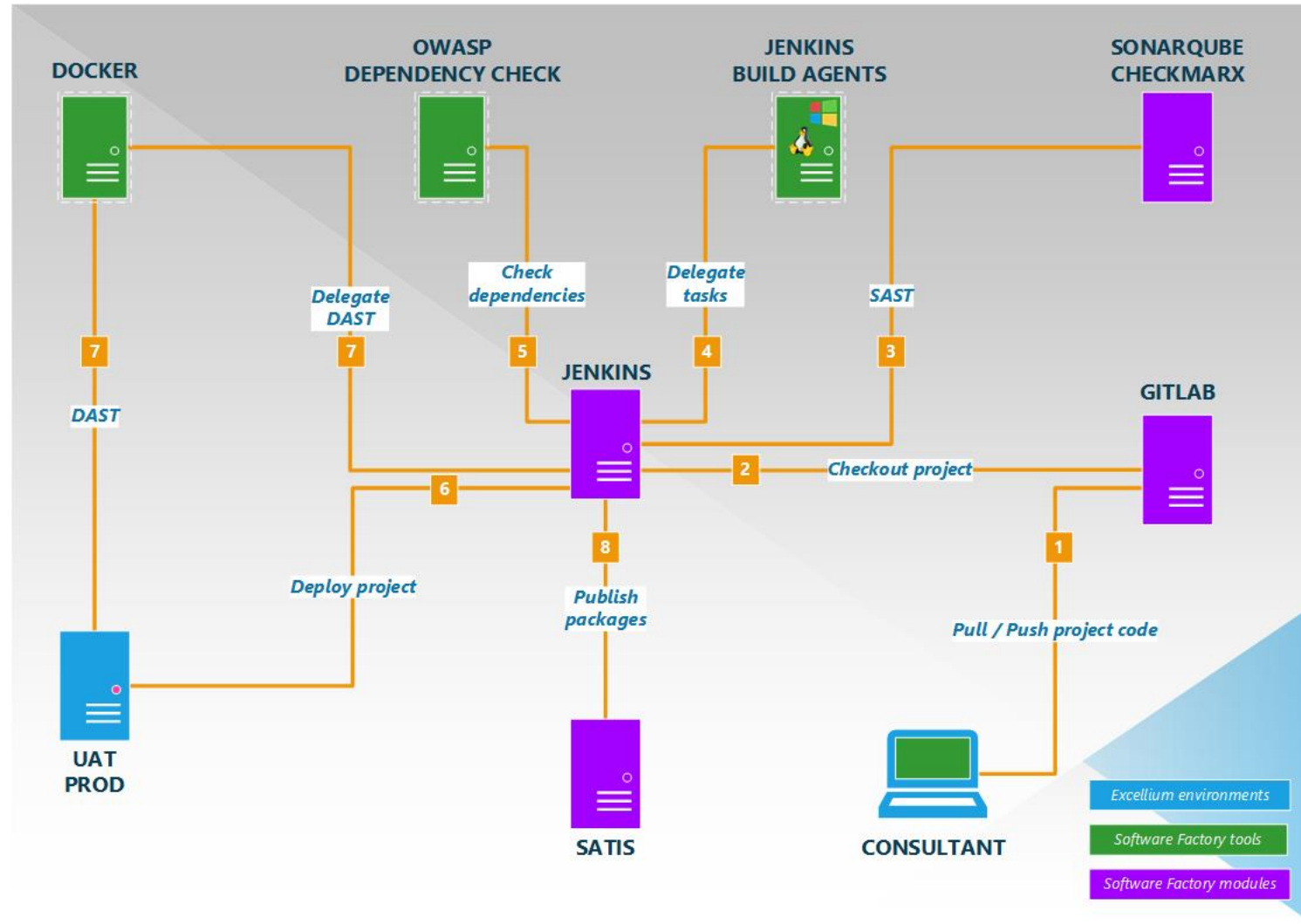
Application & Security

Example: Security checks in a Continuous Integration Platform



Application & Security

Our Software Factory for our own products



Thank You

